

Комплексна система захисту інформації

Галузевий профіль заходів із
захисту інформації (28)

Зміст

Зміст

Анотація

Галузевий профіль — розробляється галузевим органом, погоджується з Держспецзв’язку та затверджується наказом/рішенням відповідного органу. Включає лише додаткові вимоги (відмінності) відносно Базового профілю.

1. АС

Клас заходів захисту АС — УПРАВЛІННЯ ДОСТУПОМ

Цей клас зосереджується на обмеженні доступу до інформаційних систем, ресурсів та функцій лише для авторизованих користувачів, програм і пристроїв.

Перелік заходів захисту: Id-spe-ac-7-2; Автоматизоване маркування (АС-15); Атрибути безпеки та приватності (АС-16); Id-spe-ac-19-1; Id-spe-ac-19-2; Id-spe-ac-19-4.

1.0.1. id-spe-ac-7-2

Очистити або стерти інформацію з [Призначення: визначених організацією мобільних пристроїв] на основі [Призначення: визначених організацією вимог та методик очищення чи стирання] після [Призначення: визначеної організацією кількості] послідовних невдалих спроб входу в систему з пристрою.

No: 1

Name: ac_7_2_01

Type: integer

Default: 3

Інформація очищується або стирається з мобільних пристроїв на основі вимог або методів очищення або стирання після <АС-07(02)_ODP[03 кількість]> послідовних, невдалих спроб входу на пристрій

No: 2

Name: ac_7_2_odp_01

Type: string

Default: nil

Визначено мобільні пристрої, які підлягають очищенню або стиранню інформації

No: 3

Name: ac_7_2_odp_02

Type: string

Default: nil

Визначено вимоги та методи очищення чи стирання інформації з мобільних пристроїв

No: 4

Name: ac_7_2_odp_03

Type: integer

Default: 3

Визначається кількість послідовних невдалих спроб входу в систему до того, як інформація буде очищена або стерта з мобільних пристроїв

1.1. АВТОМАТИЗОВАНЕ МАРКУВАННЯ (АС-15)

No: 1

Name: ac_15_01

Type: string

Default: nil

АВТОМАТИЗОВАНЕ МАРКУВАННЯ [Вилучено: включено до МР-03]

1.2. АТРИБУТИ БЕЗПЕКИ ТА ПРИВАТНОСТІ (АС-16)

а. Визначити засоби для асоціювання (пов'язання) [Призначення: визначених організацією типів атрибутів безпеки та приватності], що приймають [Призначення: визначені організацією значення атрибутів безпеки та приватності] з інформацією, яка зберігається, обробляється та/або передається.

б. Пов'язані атрибути безпеки та приватності мають створюватися і зберігатися разом з інформацією.

с. Встановити дозволені [Призначення: визначені організацією атрибути безпеки] для [Призначення: систем, визначених організацією].

д. Визначити дозволені [Призначення: визначені організацією значення або діапазони] для кожного з встановлених атрибутів безпеки та приватності.

No: 1

Name: ac_16_c_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено типи атрибутів безпеки, які мають бути пов'язані зі значеннями атрибутів безпеки для інформації, що зберігається, обробляється та/або передається; визначено значення атрибутів конфіденційності для типів атрибутів конфіденційності; визначено системи, для яких мають бути встановлені дозволені атрибути безпеки; визначено системи, для яких мають бути встановлені дозволені атрибути конфіденційності; визначено атрибути безпеки, визначені як частина АС-16(а), які дозволені для систем; визначено атрибути конфіденційності, визначені як частина АС-16(а), які дозволені для систем; визначено значення атрибутів або діапазони для встановлених атрибутів; визначено частоту, з якою слід переглядати атрибути безпеки на предмет відповідності; визначено частоту, з якою слід переглядати атрибути конфіденційності на предмет відповідності; надано засоби для асоціювання типів атрибутів безпеки зі значеннями атрибутів безпеки для інформації, що зберігається, обробляється та/або передається надано засоби для асоціювання типів атрибутів конфіденційності зі значеннями атрибутів конфіденційності для інформації, що зберігається, обробляється та/або передається виникають зв'язки з атрибутами; зв'язки атрибутів зберігаються разом з інформацією; на основі атрибутів, визначених у АС-16_ODP[01] для систем, встановлюються наступні дозволені атрибути безпеки: атрибути безпеки; на основі атрибутів, визначених у АС-16_ODP[02] для систем, встановлюються наступні дозволені атрибути приватності: атрибути конфіденційності ; АС-16(d)

No: 2

Name: ac_16_f_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено наступні допустимі значення або діапазони атрибутів для кожного з встановлених атрибутів: значення або діапазони атрибутів; проводиться аудит змін до атрибутів; атрибути безпеки перевіряються на відповідність частота; атрибути конфіденційності перевіряються на відповідність частота

No: 3
Name: ac_16_odp_02
Type: string
Default: nil

Визначено типи атрибутів конфіденційності, які мають бути пов'язані зі значеннями атрибутів конфіденційності для інформації, що зберігається, обробляється та/або передається

No: 4
Name: ac_16_odp_03
Type: string
Default: nil

Визначено значення атрибутів безпеки для типів атрибутів безпеки

1.2.1. id-spe-ac-19-1

No: 1
Name: ac_19_1_01
Type: string
Default: nil

КОНТРОЛЬ ДОСТУПУ ДЛЯ МОБІЛЬНИХ ПРИСТРОЇВ - ВИКОРИСТАННЯ ПИСЬМОВИХ ТА ПОРТАТИВНИХ ПРИСТРОЇВ ДЛЯ ЗБЕРІГАННЯ ДАНИХ [Вилучено: Включено в МР-07]

1.2.2. id-spe-ac-19-2

No: 1
Name: ac_19_2_01
Type: list
Default: ["admin", "security_officer"]

КОНТРОЛЬ ДОСТУПУ ДЛЯ МОБІЛЬНИХ ПРИСТРОЇВ - ВИКОРИСТАННЯ ПЕРСОНАЛЬНИХ ПОРТАТИВНИХ ПРИСТРОЇВ ЗБЕРІГАННЯ ДАНИХ [Вилучено: Включено в МР-07]. АС-19(03) КОНТРОЛЬ ДОСТУПУ ДЛЯ МОБІЛЬНИХ ПРИСТРОЇВ - ВИКОРИСТАННЯ ПОРТАТИВНИХ ПРИСТРОЇВ ЗБЕРІГАННЯ ДАНИХ З НЕІДЕНТИФІКОВАНИМ ВЛАСНИКОМ [Вилучено: Включено в МР-07]

1.2.3. id-spe-ac-19-4

No: 1
Name: ac_19_4_a
Type: list
Default: ["admin", "security_officer"]

Використання незахищених мобільних пристроїв на об'єктах, що містять системи, які обробляють, зберігають або передають секретну інформацію, заборонено, за винятком випадків, коли на це є спеціальний дозвіл уповноваженої посадової особи; АС-19(04)(b)(01) заборона підключення незахищених мобільних пристроїв до систем з обмеженим доступом застосовується до осіб, яким уповноважена посадова особа дозволила використовувати незахищені мобільні пристрої на об'єктах, що містять системи, які обробляють, зберігають або передають інформацію з обмеженим доступом; АС-19(04)(b)(02) дозвіл уповноваженої посадової особи на підключення незахищених мобільних пристроїв до незахищених систем вимагається від осіб, яким дозволено використовувати незахищені мобільні пристрої на об'єктах, що містять системи, які обробляють, зберігають або передають інформацію з обмеженим доступом; АС-19(04)(b)(03) заборона використання внутрішніх або

зовнішніх модемів чи бездротових інтерфейсів у складі незахищених мобільних пристроїв поширюється на осіб, яким уповноваженою посадовою особою дозволено використовувати незахищені мобільні пристрої під час виконання службових обов'язків, а також на осіб, які не мають права на використання таких пристроїв АС-19(04)(b)(04)[01] вибірковий огляд та перевірка незахищених мобільних пристроїв та інформації, що зберігається на них, посадовими особами є обов'язковими; АС-19(04)(b)(04)[02] дотримання політики обробки інцидентів застосовується у разі виявлення секретної інформації під час випадкового огляду та перевірки незахищених мобільних пристроїв

No: 2

Name: ac_19_4_c

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Підключення захищених мобільних пристроїв до засекречених систем обмежено відповідно до політики безпеки

No: 3

Name: ac_19_4_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено посадових осіб із захисту інформації, відповідальних за огляд та перевірку захищених мобільних пристроїв та інформації, що зберігається на цих пристроях

No: 4

Name: ac_19_4_odp_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено політики безпеки, що обмежують підключення захищених мобільних пристроїв до засекречених систем

2. AU

Клас заходів захисту AU — АУДИТ ТА ПІДЗВІТНІСТЬ

Цей клас забезпечує можливість відстеження дій у системі, генерування, захист та аналіз записів аудиту для виявлення порушень політики безпеки.

Перелік заходів захисту: Неспростовність (AU-10); Id-spe-au-10-5.

2.1. НЕСПРОСТОВНІСТЬ (AU-10)

Надавайте неспростовні докази того, що особа (або процес, який діє від імені особи) виконала [Призначення: дії, визначені організацією, на які поширюється принцип неспростовності].

No: 1

Name: au_10_01

Type: list

Default: ["admin", "security_officer"]

Надаються неспростовні докази того, що особа (або процес, що діє від імені особи) виконала дії

No: 2

Name: au_10_odp

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначено дії, на які поширюється принцип неспростовності

2.1.1. id-spe-au-10-5

No: 1

Name: au_10_5_01

Type: string

Default: nil

НЕСПРОСТОВНІСТЬ - ЦИФРОВІ ПІДПИСИ [Вилучено: Включено до SI-07]

3. ІА

Клас заходів захисту ІА — ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ

Цей клас відповідає за однозначне розпізнавання користувачів або пристроїв та підтвердження їхньої справжності перед наданням доступу до системи.

Перелік заходів захисту: Id-spe-ia-2-1; Id-spe-ia-2-2; Id-spe-ia-2-12; Id-spe-ia-5-2; Id-spe-ia-5-11; Id-spe-ia-5-12; Id-spe-ia-5-15; Id-spe-ia-5-17; Id-spe-ia-7.

3.0.1. id-spe-ia-2-1

No: 1

Name: ia_2_1_01

Type: string

Default: nil

Реалізовано багатофакторну автентифікацію для доступу до привілейованих облікових записів

3.0.2. id-spe-ia-2-2

No: 1

Name: ia_2_2_01

Type: string

Default: nil

Реалізовано багатофакторну автентифікацію для доступу до непривілейованих облікових записів

3.0.3. id-spe-ia-2-12

No: 1

Name: ia_2_12_01

Type: list

Default: ["admin", "security_officer"]

Приймаються та електронним шляхом підтверджуються повноваження облікових даних особистої ідентифікації

3.0.4. id-spe-ia-5-2

Немає параметрів для цього контролю.

3.0.5. id-spe-ia-5-11

No: 1
Name: ia_5_11_01
Type: string
Default: nil

УПРАВЛІННЯ АВТЕНТИФІКАТОРОМ - АВТЕНТИФІКАЦІЯ НА ОСНОВІ АПАРАТНИХ ТОКЕНІВ [Вилучено: Включено до IA-02(01), IA-02(02)]

3.0.6. id-spe-ia-5-12

No: 1
Name: ia_5_12_odp
Type: string
Default: "автоматизований засіб моніторингу"

Визначено вимоги до якості біометрії; для біометричної автентифікації використовувати механізми, які задовольняють вимоги

3.0.7. id-spe-ia-5-15

No: 1
Name: ia_5_15_01
Type: string
Default: nil

Використовуються лише схвалені та затверджені уповноваженим органом продукти та послуги

3.0.8. id-spe-ia-5-17

No: 1
Name: ia_5_17_01
Type: string
Default: "автоматизований засіб моніторингу"

Використовуються механізми виявлення атак із використанням штучно виготовлених артефактів для біометричних автентифікаторів

3.1. id-spe-ia-7

No: 1
Name: ia_7_01
Type: list
Default: ["default_deny_rule", "abac_rule_1"]

Впроваджено механізми автентифікації в криптографічний модуль, який відповідає вимогам чинних законів, виконавчих розпоряджень, директив, політик, правил, стандартів та рекомендацій для такої автентифікації

4. МР

Клас заходів захисту МР — ЗАХИСТ НОСІЇВ ІНФОРМАЦІЇ

Цей клас спрямований на безпечне зберігання, транспортування, використання та знищення як цифрових, так і паперових носіїв інформації.

Перелік заходів захисту: Id-spe-mp-6; Id-spe-mp-8-4.

4.1. id-spe-mp-6

а. Очищувати [Призначення: визначені організацією системні носії] перед утилізацією, випуском за межі організаційного контролю, або перед повторним використанням [Призначення: методами та процедурами очищення, визначеними організацією].

б. Використовувати механізми очищення зі стійкістю та цілісністю, що відповідає категорії безпеки або рівню секретності інформації.

No: 1

Name: mp_6_a_01

Type: string

Default: nil

Носії інформації системи перед утилізацією піддаються очищенню за допомогою методів та процедур очищення

No: 2

Name: mp_6_a_02

Type: string

Default: nil

Носії інформації системи очищаються за допомогою методів та процедур очищення перед випуском за межі контрольованої зони

No: 3

Name: mp_6_a_03

Type: string

Default: nil

Носії інформації системи очищуються за допомогою методів і процедур очищення перед повторним використанням

No: 4

Name: mp_6_b

Type: string

Default: "автоматизований засіб моніторингу"

Застосовуються механізми очищення, надійність і цілісність яких відповідає категорії безпеки або рівню секретності інформації

No: 5

Name: mp_6_odp_01

Type: string

Default: nil

Визначено носії інформації системи, які підлягають очищенню перед утилізацією

No: 6

Name: mp_6_odp_02

Type: string

Default: nil

Визначено носії інформації системи, які підлягають очищенню перед випуском за межі контрольованої зони

No: 7

Name: mp_6_odp_03

Type: string

Default: nil

Визначені носії інформації системи, що підлягають очищенню перед повторним використанням

No: 8

Name: mp_6_odp_04

Type: string

Default: nil

Визначено методи та процедури очищення, які слід використовувати для очищення перед утилізацією

No: 9

Name: mp_6_odp_05

Type: string

Default: nil

Визначено методи та процедури очищення, які слід використовувати для очищення перед випуском за межі контрольованої зони

No: 10

Name: mp_6_odp_06

Type: string

Default: nil

Визначено методи та процедури очищення, які слід використовувати для очищення перед повторним використанням

4.1.1. id-spe-mp-8-4

No: 1

Name: mp_8_4_01

Type: string

Default: nil

Ідентифіковано носії інформації, що містять інформацію з обмеженим доступом

No: 2

Name: mp_8_4_02

Type: list

Default: ["admin", "security_officer"]

Носії інформації, що містять інформацію з обмеженим доступом, знижуються в класі перед передачею особам, які не мають необхідних дозволів на доступ

5. PE

Клас заходів захисту PE — ФІЗИЧНИЙ ЗАХИСТ І ЗАХИСТ РОБОЧОГО

Цей клас охоплює заходи контролю фізичного доступу до об'єктів організації та захисту обладнання від загроз навколишнього середовища.

Перелік заходів захисту: Маркування компонентів (PE-22).

5.1. МАРКУВАННЯ КОМПОНЕНТІВ (PE-22)

No: 1
 Name: pe_22_01
 Type: string
 Default: nil

Апаратні компоненти системи позначаються із зазначенням рівня впливу або класифікації інформації, яку дозволено обробляти, зберігати або передавати за допомогою апаратного компонента

No: 2
 Name: pe_22_odp
 Type: string
 Default: nil

Визначено апаратні компоненти системи, які підлягають маркуванню із зазначенням рівня впливу або класифікації інформації, яку дозволено обробляти, зберігати або передавати за допомогою апаратного компонента

6. SC

Клас заходів захисту SC — ЗАХИСТ ІНФОРМАЦІЙНОЇ СИСТЕМИ ТА

Цей клас охоплює механізми захисту інформації під час її передачі мережами зв'язку, криптографічний захист та ізоляцію критичних компонентів.

Перелік заходів захисту: Id-spe-sc-8-1; Встановлення ключами (SC-12); Id-spe-sc-17; Id-spe-sc-28-1; Екрановані камери (SC-44); Id-spe-sc-49; Апаратний захист (SC-51).

6.0.1. id-spe-sc-8-1

No: 1
 Name: sc_8_1_odp
 Type: string
 Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {запобігти несанкціонованому розголошенню інформації; виявити зміни в інформації}

6.1. ВСТАНОВЛЕННЯ КЛЮЧАМИ (SC-12)

Встановити та управляти криптографічними ключами для криптографічних засобів, які використовуються в системі відповідно до [Призначення: визначені організацією вимоги до генерації, поширення, зберігання, доступу та знищення ключів].

No: 1
 Name: sc_12_01
 Type: string
 Default: "AES-256-GCM"

Встановлюються криптографічні ключі, коли в системі використовується криптографія відповідно до < SC-12_ODP вимог >

No: 2

Name: sc_12_02

Type: string

Default: "AES-256-GCM"

Здійснюється управління криптографічними ключами, коли в системі використовується криптографія, відповідно до вимог

No: 3

Name: sc_12_odp

Type: string

Default: nil

Визначені вимоги до генерації, розповсюдження, зберігання, доступу та знищення ключів

6.2. id-spe-sc-17

- a. Випускати сертифікати відкритого ключа відповідно до [Призначення: визначеної організацією політики сертифікації];
- b. Отримувати сертифікати відкритого ключа від затвердженого постачальника послуг.

Немає параметрів для цього контролю.

6.2.1. id-spe-sc-28-1

No: 1

Name: sc_28_1_01

Type: string

Default: "AES-256-GCM"

Реалізовані криптографічні механізми для запобігання несанкціонованому розкриттю інформації, що знаходиться в стані спокою на системних компонентах або носіях

No: 2

Name: sc_28_1_02

Type: string

Default: "AES-256-GCM"

Реалізовані криптографічні механізми для запобігання несанкціонованій модифікації інформації, що знаходиться в стані спокою на системних компонентах або носіях

6.3. ЕКРАНОВАНІ КАМЕРИ (SC-44)

Впровадити екрановані камери в [Призначення: визначену організацією систему, компонент системи або місце розташування].

No: 1

Name: sc_44_01

Type: string

Default: nil

Використовується в системі <SC-44_ODP, компоненті або місці розташування> застосування екранованої камери системному можливість

No: 2
 Name: sc_44_odp
 Type: string
 Default: nil

Визначена система, компонент системи або місце, де має бути застосований потенціал екранованої камери

6.4. id-spe-sc-49

Впровадити механізми апаратного поділу та застосування політики між [Призначення: домени безпеки, визначені організацією].

No: 1
 Name: sc_49_01
 Type: list
 Default: ["default_deny_rule", "abac_rule_1"]

Впроваджено механізми апаратного розділення та застосування політик між доменами безпеки

No: 2
 Name: sc_49_odp
 Type: list
 Default: ["default_deny_rule", "abac_rule_1"]

Визначені домени безпеки, які потребують апаратного розділення та механізмів забезпечення дотримання політики

6.5. АПАРАТНИЙ ЗАХИСТ (SC-51)

- Перевіряти правильність роботи [Призначення: визначені організацією функції безпеки та приватності].
- Виконувати перевірку [Вибір (один або кілька): [Призначення: визначені організацією системні перехідні стани]; за командою користувача з відповідними повноваженнями; [Призначення: визначена організацією частота]].
- Повідомляти [Призначення: визначені організацією персонал або посадові особи] про невдалі перевірки безпеки та приватності.
- [Вибір (один або кілька): Вимкнути систему; Перезапустити систему; [Призначення: визначені організацією альтернативні дії]], коли виявляються аномалії.

No: 1
 Name: sc_51_odp_01
 Type: string
 Default: nil

Визначено компоненти системної прошивки, потребують апаратного захисту від запису; які

No: 2
 Name: sc_51_odp_02
 Type: list
 Default: ["admin", "security_officer"]

Визначені уповноважені особи, які повинні виконувати процедури вимкнення та повторного ввімкнення апаратного захисту від запису; SC-51a. використовується апаратний захист від запису для компонентів мікропрограми системи; SC-51b.[01] впроваджено спеціальні процедури для уповноважених осіб для ручного вимкнення апаратного захисту від запису для модифікацій мікропрограми; SC-51b.[02] реалізовано спеціальні

процедури для уповноважених осіб для повторного увімкнення захисту від запису перед поверненням до робочого режиму

7. SI

Клас заходів захисту SI — ЦІЛІСНІСТЬ СИСТЕМИ ТА ІНФОРМАЦІЇ

Цей клас спрямований на захист системи від шкідливого коду, виявлення вразливостей та запобігання несанкціонованим змінам інформації.

Перелік заходів захисту: Id-spe-si-7.

7.1. id-spe-si-7

a. Впровадити механізми захисту від спаму в точках входу та виходу системи, щоб виявляти та протидіяти небажаним повідомленням.

b. Оновлювати механізми захисту від спаму, коли доступні нові механізми відповідно до організаційної політики та процедур управління конфігурацією.

No: 1

Name: si_7_odp_01

Type: string

Default: nil

Визначено програмне забезпечення, яке потребує застосування засобів перевірки цілісності для виявлення несанкціонованих змін

No: 2

Name: si_7_odp_02

Type: string

Default: nil

Визначено прошивку, яка потребує застосування інструментів перевірки цілісності для виявлення несанкціонованих змін

No: 3

Name: si_7_odp_03

Type: string

Default: nil

Визначена інформація, яка потребує застосування засобів перевірки цілісності для виявлення несанкціонованих змін

No: 4

Name: si_7_odp_04

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначені дії, яких слід вжити при виявленні несанкціонованих змін у програмному забезпеченні

No: 5

Name: si_7_odp_05

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначені дії, яких слід вжити несанкціонованих змін у прошивці; при виявленні SI-07_ODP[06] визначені дії, яких слід вжити несанкціонованих змін до інформації; при виявленні SI-07a.[01] використовуються засоби перевірки цілісності для виявлення несанкціонованих змін у програмному забезпеченні; SI-07a.[02] використовуються засоби перевірки цілісності для виявлення несанкціонованих змін у мікропрограмі; SI-07a.[03] використовуються засоби перевірки цілісності для виявлення несанкціонованих змін до інформації; SI-07b.[01] виконуються дії при виявленні несанкціонованих змін у програмному забезпеченні; SI-07b.[02] виконуються дії несанкціонованих змін у прошивці; при виявленні SI-07b.[03] виконуються дії несанкціонованих змін в інформації. при виявленні